# Nhill 3.0 — Database component

*Français : ../fr/base-de-donnees.md*

All Nhill data is in a PostgreSQL database (version 15 or later), in a dedicated `nhill` schema. Only the Nhill server connects to it; the applications always go through the API.

| Topic | Document |
|---|---|
| Tables, columns, constraints, policies and functions (generated from a migrated database) | database-reference.md |
| Installation and backups on the production VPS | vps-deployment-hostinger.md § 4, 7 and 8 |
| Manual installation (PostgreSQL or Supabase) | installation-guide.md § 4.3 and 4.4 |
| Retention periods | `legal/en/15-retention-policy.md` |

## 1. Possible hosting

| Hosting | Conditions |
|---|---|
| PostgreSQL on the same server (chosen for production) | installed by `deploy/vps/provision.sh`; listens locally only (port 5432 closed to the network) |
| Self-hosted PostgreSQL elsewhere | empty `nhill` database, account able to create roles for the installation, `scram-sha-256` authentication, TLS if the database is remote |
| Supabase | “Session pooler” (port 5432), never the “transaction pooler”; no Supabase API key is used; the `nhill` schema is closed to the `anon` and `authenticated` roles |

## 2. Roles

| Role | Use | Rights |
|---|---|---|
| `nhill_owner` | migrations (`NH_MIGRATION_DATABASE_URL`) | owns the schema; never used by the API |
| `nhill_app` | running server (`NH_DATABASE_URL`) | owns nothing, no definition rights, subject to row-level security, `NOBYPASSRLS`; activity log read and append only |
| `nhill_backup` | backups (`db/bootstrap/01-backup-role.sql`) | read-only (`pg_read_all_data`, read-only transactions by default); the only role allowed to read every business, for the backup dump |

The installation (Nhill Console or `nhill-server setup`) creates these roles with random passwords; the database administrator’s password is used once and not stored.

## 3. Business isolation

- The 31 business-management tables (catalogue, customers and suppliers, documents, stock, purchases, expenses, payments, till…) have row-level security **enabled and forced** (it also applies to the table owner). Platform tables (accounts, memberships, subscriptions, activity log…) are only read through the server’s queries, with only the rights the application role needs (activity log: read and append only).

- The server sets `app.establishment_id` at the start of each transaction; without it, no row is visible or writable.
- References between tables use composite keys (business, identifier): a row cannot point to another business's data, even through a programming error.
- Console statistics go through functions that only return aggregates (counts, amounts per currency), never content.

These rules are checked by the server tests and by the installation check screen of Nhill Console (role without privileges, forced security, functions with a fixed `search_path`, no data visible and no write without a business).

## 4. Migrations

- Files `db/migrations/NNNN_name.sql`, applied in order by `nhill-server migrate` (or at the first start of an installation); version 3.0.0: migrations 0001 to 0015.
- Each applied migration is recorded with its SHA-256 checksum in `schema_migrations`: a migration modified afterwards is refused. Never modify a published migration; add a new one.
- The server refuses to start if a migration is pending, and refuses a database migrated by a newer version (rollback: restore the copy taken before the update).
- The 3.0.0 migrations: 0012 (configurable plans and rights), 0013 (document notices, till invoices), 0014 (permanent erasure of a business, billing archive), 0015 (searches with literal `%` and `_`).

## 5. Backups and restore

| Item | How it works |
|---|---|
| Backup | `deploy/backup/nhill-backup.sh` (service `nhill-backup.timer`, every night around 02:30): `pg_dump` in custom format with the `nhill_backup` role, encrypted on the fly with `age` (no plain copy on disk), SHA-256 checksum alongside |
| Retention | 14 days on the VPS (`NH_BACKUP_KEEP_DAYS`); off-site copy possible at each backup (`NH_BACKUP_OFFSITE_CMD`) |
| Key | only the **public** `age` key is on the server; the private key, needed to restore, is kept offline |
| Restore | `deploy/backup/nhill-restore.sh BACKUP KEY NEW_DATABASE`: checks the checksum, restores into a **new** database, shows migrations, businesses and security; switching over is then done by hand |
| Restore test | `deploy/vps/nhill-restore-test.sh` on a separate machine: throwaway PostgreSQL, restore, counts, check of forced security and of the application role's isolation, then deletion; to do every month |

Full procedure, including switching over on the VPS: vps-deployment-hostinger.md § 7 and 8.

## 6. Retention and erasure

| Data | Rule | Implementation |
|---|---|---|
| A business after its access ends | read-only and export for 90 days, then permanent erasure | Nhill Console › Businesses › "To erase"; function `nh_erase_establishment` (`SECURITY DEFINER`, table owner): documents, customers, products, stock, payments, activity log and accounts used only in that business |
| Paid subscription orders of an erased business | 10 years | table `billing_archive` |

| Data | Rule | Implementation |
|---|---|---|
| E-mails sent or abandoned | 30 days | server background job |
| Ended sessions | 90 days | server background job |
| Backups | 14 days on the VPS | `nhill-backup.sh`; erased data disappears from the backups as they rotate |

## 7. Useful operating queries

Run with a database administration account (never with `nhill_app`):

```
-- applied migrations
SELECT version, applied_at FROM nhill.schema_migrations ORDER BY version;
-- tables with forced row-level security (31 in 3.0.0; list in the reference)
SELECT count(*) FROM pg_class c JOIN pg_namespace n ON n.oid = c.relnamespace
 WHERE n.nspname = 'nhill' AND c.relrowsecurity AND c.relforcerowsecurity;
-- failed e-mails (relay error, without password)
SELECT template, attempts, last_error, created_at FROM nhill.email_outbox WHERE status =
'failed' ORDER BY created_at DESC LIMIT 20;
```